

Manual 29 — Aseguramiento de la cadena de suministro de software e IA — Edición controlada es-419

Estado: traducción controlada no oficial del proyecto. Conserva la separación entre obligaciones vinculantes, estándares publicados, especificaciones voluntarias y guías de implementación.

Jerarquía de fuentes controlada

- La ley, regulación, cláusula de contratación pública y contrato aplicables conservan prioridad vinculante.
- NIST SP 800-218 SSDF versión 1.1 es la línea base final estable utilizada.
- NIST SP 800-218A es el perfil comunitario final de IA utilizado junto con SSDF 1.1.
- SLSA versión 1.2 es la especificación aprobada vigente utilizada.
- Las guías de CISA y fuentes similares se tratan como guía salvo que otra fuente las haga obligatorias.
- NIST SP 800-218 Rev. 1 / SSDF versión 1.2 permanece como borrador y vigilancia de cambios.

Cada capítulo conserva aplicabilidad, responsable, procedimiento, evidencia, revisión/prueba, remediación y disparador de reevaluación.

Capítulo 01 — Propósito, alcance y límites de fuentes

Definir el alcance de software, modelos, componentes, proveedores, productos, jurisdicciones, contratos y adquisiciones antes de seleccionar controles. Evidencia: declaración de alcance y registro de fuentes. Responsable: líder de aseguramiento de cadena de suministro.

Capítulo 02 — Inventario del ecosistema de proveedores y componentes

Mantener un inventario con propietario que relacione proveedores materiales, paquetes, modelos, API, fuentes de datos, servicios de compilación, alojamiento y dependencias de producto. Evidencia: registro y mapa de dependencias.

Capítulo 03 — Gobierno y responsabilidades de desarrollo seguro

Establecer política, funciones responsables, segregación de funciones, escalamiento, autoridad de excepciones y objetivos medibles. Evidencia: política, RACI, cartas y registro de excepciones.

Capítulo 04 — Preparación organizacional de SSDF

Mapear las prácticas SSDF aplicables a procedimientos, herramientas, formación, requisitos de seguridad y expectativas de proveedores sin presentar la guía de NIST como certificación. Evidencia: matriz de implementación SSDF.

Capítulo 05 — Seguridad del entorno de desarrollo

Mantener líneas base aprobadas para entornos de desarrollo, compilación, prueba y entrenamiento de modelos, incluyendo acceso, configuración, actualización, monitoreo y cambios según riesgo.

Capítulo 06 — Gobierno de código fuente y repositorios

Usar repositorios controlados con propiedad definida, acceso autenticado, protección de ramas, política de revisión, auditabilidad, retención y recuperación.

Capítulo 07 — Identidad, acceso y administración privilegiada de compilación

Aplicar mínimo privilegio, identidades administradas, autenticación fuerte apropiada, revisión periódica de acceso y acceso de emergencia controlado en plataformas relevantes.

Capítulo 08 — Controles de ramas, revisión y cambios

Exigir cambios trazables, independencia de revisión según riesgo, verificaciones obligatorias, rutas de integración controladas y manejo documentado de cambios de emergencia.

Capítulo 09 — Descubrimiento de dependencias e inventario de componentes

Identificar dependencias directas, transitivas, de ejecución, compilación, modelo, complemento y herramienta mediante métodos aprobados y asignar propietario a componentes materiales.

Capítulo 10 — Generación, formatos y ciclo de vida de SBOM

Generar y conservar SBOM legibles por máquina cuando corresponda, vincularlos con versiones controladas, definir formatos admitidos y validar identidad y relaciones de componentes.

Capítulo 11 — VEX y evidencia del estado de vulnerabilidades

Cuando se usen afirmaciones de estado de vulnerabilidad, vincularlas a producto/versión, identificador, justificación, evidencia, responsable y disparador de revisión.

Capítulo 12 — Ingreso de código abierto e interfaces de licenciamiento

Evaluar procedencia, mantenimiento, historial de seguridad, obligaciones de licencia, avisos, restricciones y uso/distribución previsto antes de aprobar componentes abiertos.

Capítulo 13 — Aseguramiento de bibliotecas y paquetes de terceros

Usar fuentes aprobadas, versiones o identificadores inmutables cuando sea práctico y criterios documentados de aceptación de componentes/proveedores.

Capítulo 14 — Seguridad de servicios de compilación y CI/CD

Gobernar CI/CD con configuraciones aprobadas, acceso administrativo restringido, definiciones protegidas, integraciones controladas, registros de auditoría y revisión de cambios.

Capítulo 15 — Consideraciones de compilación hermética/reproducible

Evaluar entradas no declaradas, variabilidad de entorno, deriva de herramientas y necesidades de reproducibilidad; aplicar técnicas apropiadas cuando lo justifique el riesgo o una obligación.

Capítulo 16 — Firma y verificación de artefactos

Definir autoridad de firma, identidades o claves aprobadas, proceso protegido, política de verificación, revocación y requisitos de verificación del consumidor.

Capítulo 17 — Arquitectura de procedencia y atestaciones

Generar procedencia o atestaciones desde procesos confiables, vincularlas con identidades inmutables y definir la política del verificador. Evidencia: atestaciones y resúmenes de verificación.

Capítulo 18 — Implementación de pistas Build y Source de SLSA

Seleccionar objetivos de pista/nivel SLSA v1.2 aplicables, documentar brechas, satisfacer requisitos antes de declarar cumplimiento y distinguir madurez interna de certificación externa.

Capítulo 19 — Gobierno de secretos, claves, tokens y material de firma

Usar almacenamiento aprobado, credenciales acotadas, rotación, control de acceso, monitoreo y procedimientos de incidente para secretos de desarrollo y cadena de suministro.

Capítulo 20 — Aseguramiento de contenedores, imágenes y componentes de infraestructura

Usar fuentes aprobadas, versiones controladas, controles de vulnerabilidad e integridad, registros de linaje y firma/verificación según riesgo.

Capítulo 21 — Procedencia de modelos de IA y controles de su cadena de suministro

Registrar origen, versión, proveedor, linaje de entrenamiento/ajuste cuando esté disponible, restricciones de licencia/uso, identificadores de integridad, evaluación, propietario y dependencias materiales.

Capítulo 22 — Procedencia de datos de entrenamiento y evaluación

Registrar fuente, autorización o licencia, sensibilidad, calidad, transformaciones, linaje, retención y limitaciones de uso de datos materiales.

Capítulo 23 — Gobierno de componentes, complementos, herramientas y agentes de IA

Inventariar componentes y servicios de soporte de IA, documentar permisos y límites de confianza, exigir evidencia de proveedor/procedencia y reevaluar cambios materiales.

Capítulo 24 — Aseguramiento de modelos, API y proveedores de servicios externos

Evaluar seguridad, privacidad, disponibilidad, tratamiento de datos, notificación de incidentes, subcontratistas, derechos de evidencia, cambios, salida y compromisos contractuales.

Capítulo 25 — Descubrimiento, priorización y respuesta a vulnerabilidades

Relacionar vulnerabilidades con productos/componentes afectados, priorizar según riesgo, asignar compromisos de remediación, validar cierre y conservar decisiones de riesgo.

Capítulo 26 — Gobierno de fuentes de paquetes e integridad de dependencias

Gobernar espacios de nombres, registros aprobados, nombres de componentes, cambios de proveedor, señales de integridad y comportamiento inesperado de dependencias para revisar anomalías materiales.

Capítulo 27 — Aprobación de liberación, distribución y reversión

Exigir puertas de liberación, identidad del artefacto, pruebas requeridas, verificaciones de procedencia/firma, SBOM/VEX cuando aplique, autoridad de aprobación, distribución controlada y capacidad de reversión.

Capítulo 28 — Respuesta a incidentes y compromiso de cadena de suministro

Integrar escenarios de compromiso de proveedores, componentes, repositorios, compilación, firma, modelos y datos en respuesta a incidentes, recuperación y acciones correctivas.

Capítulo 29 — Métricas, excepciones y aceptación de riesgo

Medir propiedad de dependencias, cobertura de verificación, cobertura SBOM, antigüedad de vulnerabilidades, vigencia de evidencia de proveedores, excepciones y objetivos de aseguramiento. Exigir aceptación de riesgo con plazo.

Capítulo 30 — Aseguramiento, pruebas y validación de evidencia

Realizar aseguramiento independiente basado en riesgo mediante inspección de evidencia, revisión de configuración, verificación de artefactos/procedencia, trazabilidad de liberaciones y pruebas de operación de controles.

Capítulo 31 — Localización, accesibilidad, licenciamiento y control de fuentes

Mantener paridad controlada EN/es-419/pt-BR, identificar traducciones del proyecto como no oficiales, preservar límites de licencia/fuente y validar accesibilidad, representación y control de versiones.

Capítulo 32 — Hoja de ruta de liberación, procedencia, sumas de comprobación y publicación secuencial

Generar candidatos DOCX/PDF reproducibles EN/es-419/pt-BR, vincular identidades SHA-256 y digest del artefacto, realizar QA determinista sin regeneración, almacenar exactamente los bytes verificados, exigir Manual 28 publicado y reconciliar el estado únicamente con una matriz final completamente verde.